SIMATS ENGINEERING

Saveetha Institute of Medical and Technical Sciences

CSA6303 - Threat Intelligence and Network Security

A1 - Threat Intelligence Report

Assessment Answers

Subject	Threat Intelligence
Course Outcome	CO3
Total Marks	50
Questions	5 (all compulsory)
Marks per Question	10
Reg. No	192465038
Name	THAMMISETTI RAJU
Faculty	Dr. V. Parthipan
Slot	A

Instructions

Answer all questions. Support answers with examples and diagrams where appropriate.

CO3: Perform threat analysis using intelligence models and utilize industry tools for monitoring and detection.

Code of Conduct

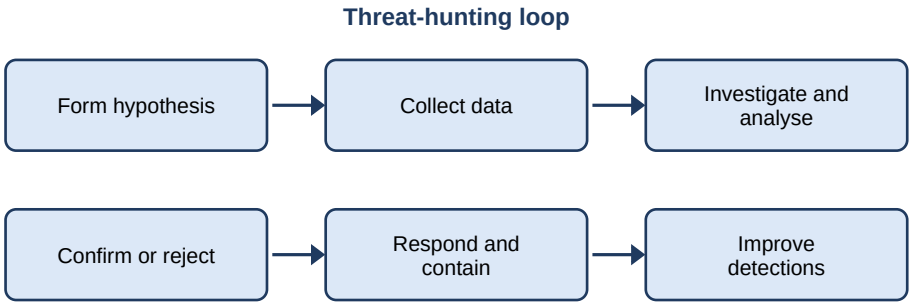
I THAMMISETTI RAJU / 192465038 (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of Student: _____

Question 1: Threat Hunting Techniques [10]

Scenario: unusual login times, unexpected processes and connections to unfamiliar external servers suggest an intruder inside the network.

Introduction. Threat hunting is the proactive, human-led search for adversaries that have evaded automated controls. It assumes a breach has already happened and looks for evidence in logs, endpoints and network traffic instead of waiting for an alert.



1. Hypothesis-driven hunting

Hunts start from a testable statement mapped to MITRE ATT&CK, for example: *"A compromised account is being used outside business hours for lateral movement (T1078 Valid Accounts, T1021 Remote Services)."* The hypothesis decides which data and queries are needed.

2. Authentication and account analysis (unusual login times)

- Baseline each user's normal hours, source hosts and locations, then list logins outside that baseline (Windows events 4624 success, 4625 failure, 4648 explicit credentials, 4672 special privileges).
- Look for impossible travel, VPN logins from new countries, many failures followed by a success (brute force or password spraying), and service accounts logging in interactively.
- Check privilege changes and new accounts (4720, 4728, 4732).

3. Endpoint and process analysis (unexpected processes)

- Review process trees (Sysmon Event ID 1 / EDR telemetry) for suspicious parent-child chains such as *winword.exe -> powershell.exe* or *svchost.exe* started from a user folder.
- Use **stacking / frequency analysis**: count how many hosts run each binary and investigate the rare ones; verify digital signatures and hashes.
- Hunt for persistence: Run/RunOnce registry keys, scheduled tasks, new services, WMI subscriptions, startup folders.
- Inspect memory for injected code, encoded PowerShell, and credential dumping (LSASS access).

4. Network analysis (connections to unfamiliar servers)

- **Beaconing detection:** look for connections at regular intervals and constant packet size, which indicate command-and-control (C2).
- **Long-tail analysis** of destination domains and IPs; check newly registered domains, odd ports and low-reputation hosts.
- Inspect DNS for very long or random subdomains (DNS tunnelling / DGA), and TLS fingerprints (JA3) for unusual clients.
- Look for internal lateral movement over SMB, RDP, WMI and PsExec between workstations.

5. Intelligence-driven hunting and IOC sweeps

Compare hashes, IPs and domains against threat-intelligence feeds (MISP, AlienVault OTX, VirusTotal) and sweep all endpoints and logs for matches. Pivot from one confirmed indicator to related hosts, users and files.

6. Outcome

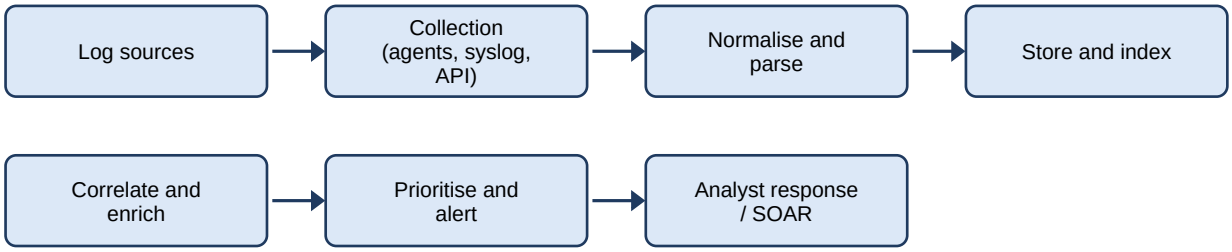
Example: a finance user logs in at 02:10, an unsigned *updater.exe* appears in *AppData*, and the host contacts a domain registered 3 days ago every 60 seconds. This is strong evidence of compromise, so the host is isolated, the account reset, the IOCs blocked, and the detection rule is added to the SIEM for future coverage.

Question 2: SIEM Tools and Security Monitoring [10]

Scenario: a SIEM reports many suspicious login attempts and unusual outbound connections.

Introduction. A SIEM (Security Information and Event Management) system, such as Splunk, IBM QRadar, Microsoft Sentinel or ELK, centralises log data from the whole environment and turns it into prioritised, actionable alerts.

SIEM data pipeline



1. Event collection

Agents, forwarders, syslog and APIs gather logs from firewalls, IDS/IPS, servers, domain controllers, VPN, proxies, endpoints, DNS and cloud services. Collection must be time-synchronised (NTP) and secured so logs cannot be tampered with.

2. Normalisation and storage

Different formats are parsed into a common schema (source IP, user, event type, timestamp), indexed for fast search, and retained for compliance and forensics.

3. Analysis and correlation

Correlation rules join events across sources and time. Example rule:

- **Rule:** 10+ failed logins from one IP within 5 minutes, followed by a successful login for the same account, followed by an outbound connection to a rare external IP within 30 minutes.
- Separately, each event looks minor; together they form a likely account-takeover and C2 chain, so a single high-severity alert is raised.
- Other methods: threshold rules, statistical baselines, UEBA (user and entity behaviour analytics) and machine-learning anomaly detection.

4. Enrichment

Alerts are enriched with GeoIP, threat-intelligence reputation, asset criticality, user role and vulnerability data so that analysts see context without manual lookups.

5. Prioritisation of threats

Factor	Question asked	Example effect
Severity	How dangerous is the technique?	Successful admin login after brute force = high
Asset criticality	Is it a domain controller, DB or a test PC?	Production DB raises priority
Threat intel match	Is the IP or domain known malicious?	Match raises confidence
Confidence / fidelity	How often is this rule a false positive?	Low-noise rules rank higher
Kill-chain stage	Is it early recon or data exfiltration?	Later stage ranks higher

A risk score (roughly severity x asset value x confidence) orders the alert queue, so the analyst works on the most dangerous items first. Low-risk duplicates are suppressed or grouped, which reduces alert fatigue.

6. Response support

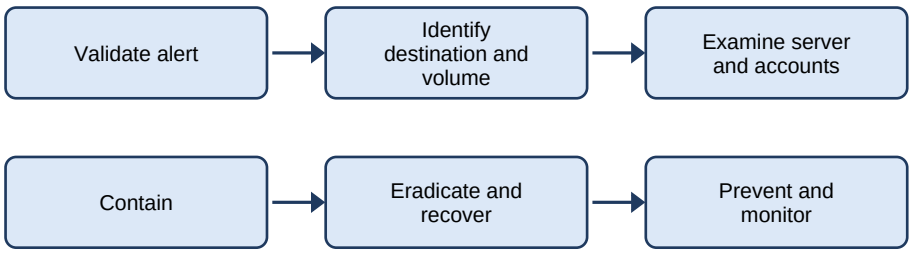
Dashboards and case management track alerts; SOAR playbooks can automatically block the IP, disable the account or isolate the host. Reports and audit trails support compliance (ISO 27001, PCI-DSS).

Question 3: Security Monitoring and Anomaly Detection [10]

Scenario: outbound traffic from a database server rises sharply during non-working hours; the server normally sends very little data.

Introduction. The deviation from baseline behaviour is a classic indicator of data exfiltration. The response is to validate the anomaly, scope it, contain it and then harden monitoring.

Investigation workflow



1. Investigating the anomaly

- **Validate:** confirm in NetFlow/firewall logs that the traffic is real (not a backup job, replication or a patch window); check the change calendar and ask the DBA.
- **Network scope:** identify destination IPs/domains, ports, protocol (HTTPS, FTP, DNS), bytes transferred and duration; check reputation with threat intelligence and look for cloud-storage or unknown hosts.
- **Server activity:** review database audit logs for large SELECT/export queries, dumps (*mysqldump*, bulk export), new users and privilege changes; review OS logs for logins and new processes or scheduled tasks.
- **Account review:** identify the account used, the login source and time; look for stolen credentials or SQL injection from the web tier.
- **Data impact:** determine which tables were read (personal, financial, intellectual property) for breach-notification and legal needs.
- **Packet capture / EDR:** capture traffic or memory if the session is still active to obtain evidence.

2. Identifying possible data exfiltration

Indicator	Meaning
Large, sustained outbound transfer at night	Bulk data theft; attackers act outside working hours
Compressed or encrypted archives (zip, rar, 7z) created on the server	Data staged before sending
Uploads to unknown IPs, cloud storage or via DNS/ICMP tunnels	Covert exfiltration channel
Query volume or result size far above normal	Mass data read by attacker or insider
Login from a new host, or service account used interactively	Compromised credentials

3. Immediate containment

Block the destination at the firewall, isolate the server (or restrict it to the management VLAN), disable or reset the suspected accounts, preserve logs and disk/memory images, and start the incident-response process and notify management.

4. Recommended monitoring and prevention measures

- **Baselining and alerting:** SIEM/UEBA rules for outbound volume per server and per hour, with after-hours thresholds.
- **Database Activity Monitoring (DAM)** for bulk queries and exports.

- **Data Loss Prevention (DLP)** and egress filtering: allow-list outbound destinations; database servers should not reach the internet directly.
- **Network segmentation** and micro-segmentation between the web, application and database tiers; proxy and IDS/IPS (Zeek, Suricata) to inspect traffic.
- **Least privilege, MFA and PAM** for administrators and service accounts; rotate credentials.
- **Encryption** of data at rest and in transit; data masking and tokenisation for sensitive columns.
- **Hardening and patching**, WAF for SQL injection, regular vulnerability scans and audits.
- **Regular threat hunts**, log retention, and incident-response drills.

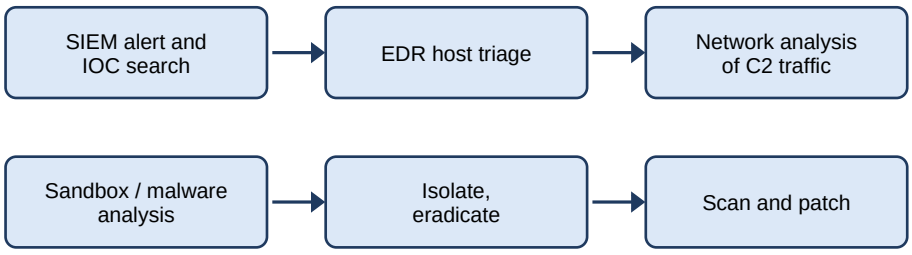
Question 4: Tools Used in the IT Industry for Threat Hunting [10]

Scenario: malware is suspected on several workstations; SIEM, endpoint detection, network traffic analysers and vulnerability scanners are available.

Introduction. No single tool shows the whole picture. Each tool covers a different data source, and together they support the identify, analyse and contain stages of the response.

Tool category (examples)	Identify	Analyse	Contain
SIEM Splunk, IBM QRadar, Microsoft Sentinel, ELK	Correlates alerts from many hosts to find the common indicator (same hash, domain, user).	Timeline of events, search for IOCs across all workstations, find patient zero and spread.	SOAR playbooks and alert rules to disable accounts, block IOCs and trigger tickets.
Endpoint Detection and Response (EDR) CrowdStrike Falcon, Microsoft Defender for Endpoint, SentinelOne	Detects malicious behaviour (ransomware-like file changes, process injection) on each workstation.	Process trees, file/registry changes, network connections per process, memory data, hash lookups.	Remote **network isolation** of the host, kill process, quarantine file, rollback changes.
Network traffic analysers Wireshark, Zeek, Suricata, NetFlow, IDS/IPS	Spots C2 beaconing, DNS anomalies and connections to malicious IPs.	Packet inspection to reveal protocols, payloads, downloaded files and exfiltrated data volume.	Block IPs/domains on the firewall, proxy or DNS sinkhole; IPS signatures to drop traffic.
Vulnerability scanners Nessus, OpenVAS, Qualys	Finds unpatched systems and weak configurations that may have been the infection route.	Matches the vulnerabilities (CVE) on infected hosts with the exploit used; shows other exposed hosts.	Prioritises patching and hardening so reinfection is prevented.
Supporting tools VirusTotal, MISP, Cuckoo/any.run sandbox, Volatility, Sysinternals	Check file hashes, domains and IPs against threat intelligence.	Sandbox behavioural analysis; memory forensics; static analysis.	Feed the confirmed IOCs back to SIEM, EDR and firewalls.

Suggested workflow

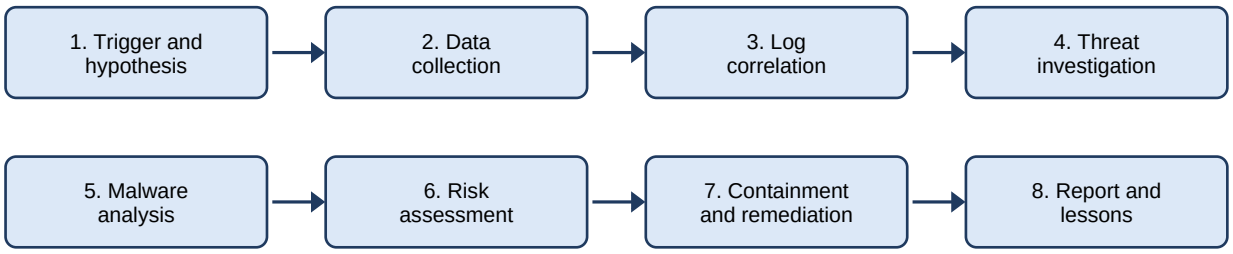


Example: the SIEM shows 6 workstations contacting *bad-domain[.]xyz*. EDR shows *invoice.exe* spawned by Outlook on each. Zeek confirms periodic beaconing. The hash is detonated in a sandbox, then EDR isolates the 6 hosts and deletes the file; the firewall blocks the domain; the vulnerability scan identifies an unpatched Office version, which is then patched.

Question 5: Integrated Threat Hunting and Incident Reporting [10]

Scenario: suspicious user logins, connections to a malicious domain and an unknown process on an employee workstation; Splunk/ELK and a threat-intelligence platform (TIP) are available.

Integrated threat-hunting process



1. Trigger and hypothesis

Hypothesis: *"A user account was compromised and the workstation is infected, communicating with a C2 server."* Define scope, time window, and affected user and host.

2. Data collection

Collect and preserve: Windows security logs, Sysmon/EDR telemetry, VPN and AD logs, DNS, proxy and firewall logs, email gateway logs. Forward them to Splunk (Universal Forwarder) or ELK (Beats/Logstash), keep timestamps synchronised, and maintain chain of custody (hashes of evidence).

3. Log correlation (Splunk / ELK)

```
index=wineventlog EventCode=4625 OR EventCode=4624
| stats count by user, src_ip, EventCode
| where count > 10

index=proxy OR index=dns dest_domain="bad-domain.xyz"
| stats count by src_ip, user, host
```

In ELK the same hunt is done in Kibana/KQL, for example `process.name:"updater.exe"` and `destination.domain:"bad-domain.xyz"`. Events are joined on user, host and IP to build a timeline: suspicious login, then process start, then DNS lookup, then connection to the malicious domain.

4. Threat investigation and indicator verification

- Submit the domain, IP and file hash to the TIP (MISP, VirusTotal, AlienVault OTX, Recorded Future) to check reputation, campaign association and related IOCs.
- Pivot on the related IOCs to search other hosts and logs for the same indicators (scoping).
- Review the process tree, parent process, command line, persistence entries and lateral-movement attempts; identify how the user was compromised (phishing, stolen password, drive-by download).

5. Malware analysis (if required)

- **Static:** hashes, strings, PE headers, imports, packers (PEStudio, strings).
- **Dynamic:** run in an isolated sandbox (Cuckoo, any.run) and observe file, registry, process and network behaviour.
- **Memory forensics:** Volatility to detect injection or hidden processes.
- Output: new IOCs (hashes, domains, mutexes, registry keys) and YARA/Sigma rules.

6. Risk assessment

Factor	Assessment example
Likelihood of compromise	High - confirmed C2 contact and unknown process

Factor	Assessment example
Impact	Depends on the user's data and access; confidentiality loss, possible lateral movement
Asset criticality	Standard workstation (medium); high if the user is an administrator
Overall rating	Likelihood x impact = High, so full incident response is triggered

7. Containment and remediation

- **Immediate:** isolate the workstation via EDR, disable and reset the account credentials and sessions, block the domain/IP in the firewall, proxy and DNS.
- **Eradication:** remove the malware and persistence, re-image the machine if integrity is uncertain, patch the exploited vulnerability.
- **Recovery:** restore from a clean backup, monitor the host closely.
- **Long term:** enforce MFA, user awareness training on phishing, least privilege, application allow-listing, network segmentation, and new SIEM detection rules based on the IOCs.

8. Threat-hunting report

Section	Content
Executive summary	What happened, impact, status and business risk in plain language
Scope and hypothesis	Hunt objective, systems, time window, data sources and tools used
Findings and timeline	Chronological events with log evidence and screenshots
IOCs and MITRE ATT&CK mapping	Hashes, IPs, domains, TTPs (e.g. T1566 Phishing, T1071 C2, T1078 Valid Accounts)
Root cause and risk rating	Entry vector, vulnerabilities exploited, risk assessment
Actions taken	Containment, eradication and recovery steps
Recommendations	Short-term and long-term remediation, new detection rules, owners and deadlines
Lessons learned	Gaps in visibility or process, and updates to playbooks

Conclusion. Integrating SIEM log analysis, threat-intelligence validation, endpoint forensics and structured reporting turns a set of isolated alerts into a confirmed, contained incident and improves future detection.